

无线局域网安全-WPA3 SAE 协议

王一诺¹(南京邮电大学 南京市 210023)¹

摘要 WPA2 长期依赖预共享密钥和四次握手机制, 但 KRACK (Key Reinstallation Attack) 表明, 协议状态机和密钥安装逻辑中的缺陷会导致密钥重装、nonce 复用和报文重放风险。WPA3-Personal 以 SAE (Simultaneous Authentication of Equals) 替代传统 PSK 认证, 通过口令认证密钥交换、临时随机数、Confirm 确认和受保护管理帧等机制, 将 WPA2 中“一次抓包、长期离线验证”的攻击模式转化为受速率限制的在线尝试。围绕 KRACK 漏洞、WPA2 安全威胁和 WPA3 SAE 改进路径展开分析, 首先说明四次握手中消息重放与密钥重装的形成过程; 随后对比 WPA2 与 WPA3 在认证、密钥协商、管理帧保护、降级防护和实现安全方面的差异; 进一步以 Dragonblood 侧信道研究为 WPA3 案例, 分析 PWE 生成和 H2E 实现中的测时泄露风险; 最后提出强制 H2E、常数时间实现、关闭过渡模式、速率限制、日志审计和固件更新等改进建议。

关键词 无线局域网安全, WPA2, KRACK 漏洞, WPA3, SAE 协议, 侧信道攻击

中图分类号 TP393.08 **文献标识码** A **DOI** (投稿时不提供 DOI 号)

Wireless LAN Security-WPA3 SAE Protocol

WANG Yinuo¹(Nanjing University of Posts and Telecommunications, Nanjing 210023, China)¹

Abstract WPA2 relies on the pre-shared key mechanism and the 4-way handshake, but KRACK shows that protocol state machines and key installation logic can cause key reinstallation, nonce reuse and replay risks. WPA3-Personal replaces traditional PSK authentication with SAE, which uses password-authenticated key exchange, ephemeral randomness, confirm authentication and protected management frames to transform low-cost offline guessing into rate-limited online attempts. This paper analyzes the KRACK vulnerability, WPA2 threats and the improvement path of WPA3 SAE. It further discusses Dragonblood as a WPA3 case study and explains side-channel measurement risks in PWE generation and H2E implementation. Finally, deployment suggestions including mandatory H2E, constant-time implementation, disabling transition mode, rate limiting, logging and firmware updates are proposed.

Keywords Wireless LAN security, WPA2, KRACK vulnerability, WPA3, SAE protocol, Side-channel attack

1 引言

1.1 研究背景与动机

无线局域网已经成为家庭、校园、企业办公和物联网终端最常见的网络接入方式。与有线网络不同, 无线信号天然向空间广播, 攻击者只要处在覆盖范围内, 就可能监听认证帧、关联帧、四次握手帧、管理帧和加密数据帧。因此, 无线局域网安全并不是单纯的“把数据加密”问题, 而是由认证、密钥协商、管理帧保护、状态机实现和运维配置共同组成的系统工程。

在 WPA2 时代, WPA2-PSK 和四次握手长期被认为能够满足家庭和中小型网络的基本安全需求。四次握手的作用是证明双方拥有相同 PMK, 并进一步派生 PTK 和 GTK, 用于保护单播、组播和广播数据。然而, KRACK 漏洞说明, 即使底层加密算法仍然可靠, 只要协议状态机允许重放关键握手消息, 客户端就可能重复安装已经使用过的密钥, 进而破坏 nonce 唯一性和重放保护^[1,4]。这类问题并不是单个密码算法被“破解”, 而是协议流程、实现逻辑与部署环境共同造成的安全失效。

WPA3-Personal 的价值在于, 它并不是简单替换一个更强的加密算法, 而是从认证入口开始改变 WPA2-PSK 的安全假设。SAE 协议将口令认证与密钥协商结合起来, 使攻击

者无法仅凭一次抓包在本地无限验证候选口令; 同时, WPA3 要求更严格的管理帧保护, 并在后续演进中引入 H2E 等机制减少侧信道风险^[2-3,6]。因此, 从 KRACK 到 WPA3 SAE 的演进, 体现了无线安全从“加密算法安全”走向“协议、实现和配置协同安全”的过程。

1.2 本文分析思路

本文围绕“KRACK 漏洞针对 WPA2, WPA3 如何逐步解决”这一主线展开。首先分析 WPA2 四次握手与 KRACK 攻击机理, 说明密钥重装为何会导致 nonce 复用和报文重放风险; 其次对 WPA2 和 WPA3 面临的主要安全威胁进行表格化对比; 随后从认证方式、密钥协商、管理帧保护、降级防护和实现加固五个层面说明 WPA3 的改进路径; 最后选择 WPA3 中的 Dragonblood 侧信道案例, 分析 PWE 生成和 H2E 实现中的测时风险, 并提出可落地的改进方案。

2 WPA2 KRACK 漏洞与安全威胁

2.1 WPA2 四次握手的作用

WPA2 中的四次握手发生在认证和关联之后, 其核心目标是证明 STA 和 AP 都拥有同一个 PMK, 并利用双方随机数 ANonce、SNonce 以及 MAC 地址派生 PTK。四次握手的大致过程为: AP 发送 ANonce, STA 生成 SNonce 并计算

到稿日期: 返修日期:

本文受 xx 基金资助。

作者名 (出身年-), 性别, 学历, 职称, 主要研究方向为 xx, E-mail: xx(通信作者)。若是 CCF 会员, 请注明。

PTK; STA 返回 SNonce 和消息认证码; AP 确认后下发组密钥并要求 STA 安装密钥; STA 最后确认握手完成。正常情况下,四次握手能够使双方在不直接传输密钥的情况下建立数据加密所需的会话密钥。

但是,四次握手不仅是一个密码计算过程,也是一个状态机过程。客户端何时安装 PTK、是否允许重复安装同一 PTK、计数器是否清零、重传消息是否触发重新初始化,都会影响最终安全性。KRACK 正是利用了这一点:攻击者并不需要知道 Wi-Fi 口令,也不需要破解 AES 或 CCMP,而是通过阻断和重放握手消息,诱导客户端重复安装已经存在的密钥^[4]。

2.2 KRACK 攻击机理

KRACK 的全称为 Key Reinstallation Attack,即密钥重装攻击。其典型攻击路径可以概括为四步。第一步,攻击者处在无线覆盖范围内,建立中间人位置,转发 STA 与 AP 之间的握手消息。第二步,攻击者在四次握手中拦截或延迟第 4 条确认消息,使 AP 认为 STA 没有成功接收第 3 条消息。第三步,AP 按照协议重传第 3 条消息,STA 收到重传后再次安装同一 PTK。第四步,如果客户端实现会在重装密钥时重置发送计数器或接收计数器,就可能导致 nonce 复用,进而产生重放、注入或部分明文恢复风险^[4]。

需要强调的是,KRACK 不是传统意义上的“破解 Wi-Fi 密码”。攻击者不一定能够得到用户口令,但可以破坏加密通信中的一次性计数器假设。对于 CCMP、GCMP 等依赖 nonce 唯一性的加密认证模式而言,nonce 复用会削弱机密性和完整性保证。在某些特定实现和网络场景中,攻击者可以重放报文、注入数据包,或者配合上层协议缺陷恢复部分流量内容。这说明,WPA2 的问题不仅包括弱口令离线破解,也包括握手重传和密钥安装状态处理不严谨。

从影响边界看,KRACK 对不同系统和加密套件的影响并不完全相同。若客户端在接收重传消息时只重新发送确认而不重装密钥,风险会明显降低;若实现会重置发送计数器或安装全零密钥,则风险会扩大。该漏洞可知安全协议标准中的“允许重传”在工程实现中必须与“密钥只安装一次”“计数器单调递增”“异常状态显式记录”等约束配合使用。否则,攻击者即使不破解密码,也可能利用协议容错机制制造安全后果。

2.3 WPA2 与 WPA3 安全威胁对比

为了更清楚地呈现 WPA2 与 WPA3 的差异,可以从攻击对象、攻击条件、影响范围和缓解机制四个维度进行比较。如表 1 所列,WPA3 SAE 对离线字典攻击和认证阶段的安全性进行了明显增强,但其实际安全仍取决于 H2E、常数时间实现、过渡模式配置和固件更新。

表 1 WPA2 与 WPA3 主要安全威胁及应对方式对比

安全威胁	WPA2 中的表现	WPA3 中的改进	仍需注意的问题	安全威胁
离线字典攻击	捕获四次握手后可长期离线验证候选口令	SAE 要求口令猜测与 AP 在线交互,显著提高攻击成本	弱口令仍可能被在线猜测,需要速率限制和口令治理	离线字典攻击
KRACK 密钥重装	重放第 3 条握手消息可能导致 PTK 重装和 nonce 复用	状态机实现要求更严格,配合 PMF 减少管理帧干扰	旧设备和未修复固件仍可能受影响	KRACK 密钥重装
伪造 AP 与钓鱼	同名 SSID 和弱认证提示容易诱导用户连接	SAE 提供相互认证,SAE-PK 可增强 AP 身份绑定	SAE-PK 部署成本较高,用户界面仍可能误导	伪造 AP 与钓鱼
降级攻击	可诱导用户使用较弱加密或不安全配置	WPA3-only 和 PMF 降低回退风险	过渡模式会重新暴露 WPA2 攻击面	降级攻击
侧信道攻击	PSK 派生和握手实现也可能泄露信息	H2E 和常数时间实现减少 PWE 泄露	厂商实现差异和缓存/计时泄露仍需测试	侧信道攻击

3 WPA3 如何逐步解决 WPA2 问题

3.1 从 PSK 到 SAE: 认证逻辑的改变

WPA2-PSK 的弱点之一在于,口令通过固定方式生成长期 PMK。攻击者只要捕获一次四次握手,就可以把握材料保存到本地,并使用字典、彩虹表或 GPU 进行无限次离线验证。WPA3-Personal 使用 SAE 替代传统 PSK 认证,使口令不再直接变成长期静态主密钥,而是参与一次交互式的口令认证密钥交换。

SAE 的关键效果是改变攻击经济性。在 SAE 中,STA 与 AP 都利用口令、随机数和群元素生成会话材料,并通过 Commit 和 Confirm 两轮交换证明双方能够计算相同密钥。攻击者即使记录完整握手,也不能像 WPA2 那样在本地快速验证候选口令;如果想猜测口令,通常必须与真实 AP 进行在线交互。这使攻击受到失败次数、连接速率、日志告警和封禁策略限制^[3]。

3.2 从固定握手到会话绑定: 降低重放与密钥混淆

KRACK 揭示的核心经验是:密钥计算正确不等于状态机安全。WPA3 在实现要求上更重视握手状态、会话上下文和管理帧保护的绑定。SAE Confirm 消息会把双方交换的

Commit 材料、计数器和身份上下文纳入认证码计算;后续四次握手则继承 SAE 输出的 PMK 继续派生 PTK 和 GTK。安全实现应确保同一会话中的密钥只安装一次,重传消息不会触发计数器复位,异常状态不会被默默忽略。

与 WPA2 相比,WPA3 并不是取消四次握手,而是把四次握手前的认证入口从 PSK 改为 SAE,并要求更严格的受保护管理帧和状态处理。也就是说,WPA3 的修复不是单点修补,而是“认证入口增强+会话上下文绑定+状态机加固+管理帧保护”的组合路径。

3.3 从可选保护到强制保护: PMF 与过渡模式风险

WPA3 要求使用 PMF (Protected Management Frames),从而减少解除认证帧、解除关联帧和部分管理帧伪造带来的影响。PMF 不能阻止所有无线干扰,但可以降低攻击者通过伪造管理帧破坏连接或诱导重连的能力。对于 KRACK 这类依赖握手重传和中间人位置的攻击,PMF 与更严格的握手状态机共同提高了攻击难度。

不过,WPA3 的过渡模式会引入新的薄弱点。许多 AP 为了兼容旧设备,会同时允许 WPA2-PSK 和 WPA3-SAE 接入。攻击者可以干扰 SAE 连接或伪造能力信息,使终端回退到 WPA2,从而重新暴露四次握手离线破解和历史实现缺

到稿日期: 返修日期:

本文受 xx 基金资助。

作者名 (出身年-),性别,学历,职称,主要研究方向为 xx, E-mail: xx(通信作者)。若是 CCF 会员,请注明。

陷。因此，真正安全的部署应优先采用 WPA3-only 模式，将旧设备放入隔离 SSID，并对降级事件进行日志记录。

4 WPA3 案例：Dragonblood 侧信道分析

4.1 案例背景

Dragonblood 是针对 WPA3 SAE 和 EAP-pwd 中 Dragonfly 握手机制的安全研究。该研究并不是说明 WPA3 整体失效，而是指出早期实现和过渡配置中存在降级、拒绝服务和侧信道问题^[9]。这与 KRACK 具有相似启示：协议目标很强，但如果实现细节、状态处理或部署配置存在缺陷，攻击者仍可能绕过设计预期。

在 SAE 中，PWE (Password Element) 生成是最容易受到侧信道关注的环节。早期实现常用“尝试-增量”方法，把口令、双方 MAC 地址和计数器输入哈希函数，反复尝试直到得到合法群元素。如果不同口令导致循环次数不同，或者不同分支触发不同缓存访问模式，攻击者就可能通过测量处理时间、缓存行为或错误响应差异来缩小口令空间。

4.2 侧信道测量思路

从防护评估角度看，侧信道测量并不需要关注破解口令本身，而应关注“输入差异是否导致可观察输出差异”。在实验室环境中，可以准备支持 WPA3 SAE 的 AP 和 STA，固定信道、距离和干扰条件，重复发起 SAE 认证请求，记录 Commit 处理时间、失败响应时间、CPU 缓存相关指标或固件日志。然后对不同口令长度、不同群组 and 不同 H2E 配置下的响应时间进行统计比较。如果某些口令类别对应明显不同的时间分布，就说明实现可能存在可利用的测时侧信道。

侧信道分析的一般链条可以概括为：第一，诱发目标执行 PWE 生成或点乘等敏感操作；第二，收集大量时间或缓存观测值；第三，使用统计检验判断观测值是否与口令候选有关；第四，将泄露信息转化为字典筛选条件。这里的关键问题不是单次测量是否精确，而是大量重复测量后是否能形成稳定区分。Dragonblood 表明，在某些实现中，缓存侧信道和计时侧信道可以帮助攻击者缩小密码字典^[9]。

在撰写或复现实验时，应把该过程定位为防护评估而非攻击利用。可记录的指标包括平均响应时间、方差、极端值比例、失败响应类别、固件日志中群组协商结果等；可采用的分析方法包括箱线图观察、方差比较和简单的显著性检验。若不同输入类别在统计上可区分，就说明实现需要修复；若加入 H2E 和常数时间库后差异消失，则说明修复有效。这种描述既能体现“具体实现”的技术细节，又不会把报告写成可直接用于攻击的操作手册。

4.3 针对侧信道的防护

WPA3 后续引入和推广 H2E (Hash-to-Element)，目的正是降低 PWE 生成过程中的不确定循环和侧信道泄露风险。H2E 应配合常数时间椭圆曲线运算、常数时间比较函数、统一错误返回和敏感中间值清除一起使用。单纯声明“支持 WPA3”并不等于实现安全，设备厂商还需要证明其密码库不会因为口令不同而产生可观测的时间差或内存访问差异。

在实现层面，常数时间并不只是“运行速度固定”这么简单，而是要求分支选择、内存访问、错误处理和输出行为都尽量不依赖秘密输入。以 PWE 生成为例，如果某个候选口令需要尝试一次即可得到合法曲线点，而另一个候选口令需到稿日期： 返修日期：

本文受 xx 基金资助。

作者名 (出身年-), 性别, 学历, 职称, 主要研究方向为 xx, E-mail: xx(通信作者)。若是 CCF 会员, 请注明。

要尝试多次，那么攻击者通过大量测时就可能区分两类口令。以点乘为例，如果不同标量触发不同运算路径，缓存访问也可能形成可测差异。因此，H2E、固定轮数、统一错误码和经过审计的密码库应作为一组措施同时使用。

对于网络管理员而言，最直接的措施包括及时升级路由器固件、关闭 WPA2/WPA3 过渡模式、优先启用 H2E、限制认证失败速率，并记录异常 Commit 请求、协商群组变化和降级事件。对于教学和测试场景，可以把 Dragonblood 作为案例说明：WPA3 解决了 WPA2 的许多结构性问题，但新的 PAKE 实现仍需要经受侧信道和兼容性测试。

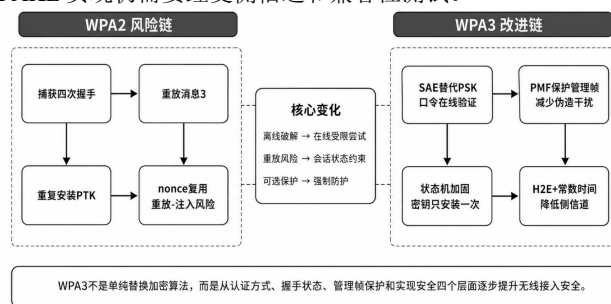


图1 从 KRACK 风险到 WPA3 SAE 安全增强的流程关系

5 安全体系与关键技术对比

5.1 安全域划分

从安全体系看，WPA2 与 WPA3 都涉及口令域、认证域、密钥派生域、数据保护域和管理控制域。WPA2 的问题集中在口令域和握手状态机：弱口令可被离线验证，四次握手重传可能触发密钥重装。WPA3 通过 SAE 增强认证域，通过 PMF 增强管理控制域，通过 H2E 和常数时间实现增强实现安全域。

这些安全域不是孤立的。即使 SAE 抵抗离线字典攻击，如果用户使用极弱口令，在线猜测仍然可能成功；即使启用 PMF，如果过渡模式长期开放，终端仍可能被诱导回退；即使标准推荐 H2E，如果厂商实现没有做到常数时间，侧信道仍可能泄露口令相关信息。因此，WPA3 的安全收益需要协议、实现和运维共同保证。

与 WPA2 相比，WPA3 更强调安全域之间的联动。例如，认证域中的 SAE 会把口令猜测限制在在线交互中，管理域中的 PMF 会减少伪造管理帧造成的异常重连，运维域中的日志审计又可以发现连续失败和降级尝试。只有这些环节同时工作，才能把 KRACK 暴露出的状态机风险、WPA2-PSK 暴露出的离线破解风险以及 Dragonblood 暴露出的实现侧信道风险一并纳入防护范围。

5.2 密钥协商、加密、认证与签名机制

密钥协商方面，WPA2-PSK 依赖预共享口令派生 PMK，再通过四次握手派生 PTK；WPA3 SAE 则使用 Dragonfly 口令认证密钥交换，通过 Commit 和 Confirm 形成 PMK。加密方面，两者都可以使用 CCMP 或 GCMP 保护数据帧，但 WPA3 对密钥来源和管理帧保护提出了更高要求。认证方面，WPA2 主要证明双方拥有同一 PSK，WPA3 SAE 则通过 PAKE 实现更强的相互认证和前向保密。

签名机制不是基础 SAE 的必要组成部分，但 SAE-PK 可以引入 AP 公钥和签名验证，增强对邪恶双胞胎 AP 的识别能力。SAE-PK 的价值在于把“知道同一口令”进一步扩展为“连接到具有可验证公钥身份的 AP”。不过，SAE-PK 也带来证书分发、用户提示和兼容性管理问题，因此更适合校园、企业访客网络或需要明确 AP 身份绑定的场景。

6 总结与展望

6.1 针对 WPA2 遗留网络的建议

仍在使用 WPA2 的网络应首先修复 KRACK 相关实现缺陷，确保客户端和 AP 在重传握手消息时不会重复安装密钥，也不会复位 nonce 或重放计数器。其次，应使用强随机口令，避免生日、手机号、默认密码和简单数字组合。再次，应启用 PMF 和较新的加密套件，并关闭 TKIP 等旧机制。对于无法升级的旧设备，应放入隔离网络，限制其访问内部资源。

6.2 针对 WPA3 SAE 部署的建议

WPA3 部署应优先选择 WPA3-only 模式，减少过渡模式带来的降级风险。AP 应强制或优先启用 H2E，限制可协商群组，使用常数时间密码库，并对认证失败、异常 Commit 请求和降级事件进行日志审计。终端侧应在发现目标网络安全能力突然降低时给出提示，而不是静默回退到 WPA2。对于学校和企业网络，还可以结合 802.1X、证书和设备准入策略进一步提升身份管理能力。

实际检查时，可从六项清单入手：第一，确认 AP 是否已经修复 KRACK 相关固件；第二，确认 WPA3 是否运行在纯 SAE 模式而非长期过渡模式；第三，确认是否启用 PMF 且不允许用户关闭；第四，确认 H2E 和强曲线组是否启用；第五，检查弱口令、默认口令和访客口令更新策略；第六，检查日志中是否记录认证失败、降级、异常重连和大量 Commit 请求。该清单能把论文中的协议分析转化为可执行的部署步骤。

6.3 面向未来的改进方向

未来无线安全改进应沿三个方向推进。第一，形式化验证应覆盖 SAE、四次握手和状态机实现，避免只证明数学核心而忽略重传、异常和回退路径。第二，侧信道测试应成为 WPA3 设备认证的一部分，重点验证 PWE 生成、H2E、点乘和比较函数是否具有可观察差异。第三，随着后量子密码标准化推进，WPA 后续版本需要考虑口令认证密钥交换与后量子密钥封装机制的混合设计，以应对长期安全需求^[8]。

7 总结

KRACK 漏洞说明，WPA2 的风险并不只来自弱口令和离线字典攻击，也来自四次握手状态机和密钥安装逻辑中的实现缺陷。WPA3 SAE 的改进路径可以概括为：用 SAE 替代 PSK 认证，减少离线验证；用临时随机数和 Confirm 确认增强会话绑定；用 PMF 保护管理帧；用 H2E 和常数时间实现降低侧信道风险；用 WPA3-only、速率限制和日志审计减少降级与在线猜测。

因此，WPA3 不是对 WPA2 的单点修补，而是从认证、密钥协商、管理帧保护和实现安全多个层面对无线局域网安全体系进行重构。与此同时，Dragonblood 案例也提示了 WPA3 仍然需要正确实现和正确配置。只有把协议设计、

到稿日期： 返修日期：

本文受 xx 基金资助。

作者名 (出身年-), 性别, 学历, 职称, 主要研究方向为 xx, E-mail: xx(通信作者)。若是 CCF 会员, 请注明。

固件实现、部署策略和运维审计结合起来，WPA3 SAE 才能真正发挥抵抗离线字典攻击、降低 KRACK 类状态机风险和提升无线接入安全基线的作用。

参考文献

[1] IEEE Computer Society. IEEE Std 802.11-2020: IEEE Standard for Information Technology--Telecommunications and Information Exchange between Systems Local and Metropolitan Area Networks--Specific Requirements Part 11: Wireless LAN Medium Access Control (MAC) and Physical Layer (PHY) Specifications[S]. New York: IEEE, 2021.

[2] Wi-Fi Alliance. WPA3 Specification Version 3.3[S]. Austin: Wi-Fi Alliance, 2023.

[3] HARKINS D. Dragonfly Key Exchange: RFC 7664[S/OL]. IETF, 2015.

[4] VANHOEF M, PIESENS F. Key Reinstallation Attacks: Forcing Nonce Reuse in WPA2[C]//Proceedings of the 2017 ACM SIGSAC Conference on Computer and Communications Security. New York: ACM, 2017: 1313-1328.

[5] VANHOEF M, RONEN E. Dragonblood: Analyzing the Dragonfly Handshake of WPA3 and EAP-pwd[C]//2020 IEEE Symposium on Security and Privacy. New York: IEEE, 2020: 517-533.

[6] FAZ-HERNANDEZ A, SCOTT S, SULLIVAN N, et al. Hashing to Elliptic Curves: RFC 9380[S/OL]. IETF, 2023.

[7] BARKER E. Recommendation for Key Management: Part 1-General: NIST Special Publication 800-57 Part 1 Revision 5[S]. Gaithersburg: NIST, 2020.

[8] National Institute of Standards and Technology. Module-Lattice-Based Key-Encapsulation Mechanism Standard: FIPS 203[S]. Gaithersburg: NIST, 2024.

[9] DWORKIN M. Recommendation for Block Cipher Modes of Operation: Galois/Counter Mode (GCM) and GMAC: NIST Special Publication 800-38D[S]. Gaithersburg: NIST, 2007.

[10] HARKINS D. Simultaneous Authentication of Equals: A Secure, Password-Based Key Exchange for Mesh Networks[C]//2008 Second International Conference on Sensor Technologies and Applications. New York: IEEE, 2008: 839-844.

作者联系方式

联系电话: 18961379706 邮箱: 1208987279@qq.com